

Задание 1. Аналитический отчет по инцидентам ИБ в DLP

Отчетный период: [месяц]

Источник: DLP

Всего инцидентов: 43

1. Методика анализа

В рамках анализа инцидентов была проведена классификация каждого события по нескольким факторам:

- тип события
- категория данных
- дополнительные коэффициенты в виде: масштаб утечки, умысел/инсайдер, наличие бота в мессенджерах, рецидив.

Детальные данные аналитики и сама модель содержатся в файле:

«Реестр инцидентов DLP.xlsx».

Ссылки на разделы:

[2. Наиболее рискованные пользователи](#)

[3. Повторяющиеся нарушения](#)

[4. Основные каналы утечки](#)

[5. Рекомендации](#)

2. Наиболее рискованные пользователи

На основе оценки критичности и уровня риска каждого события был сформирован топ пользователей с наивысшими показателями угрозы:

Пользователь	Уровень риска	Критичность
Пользователь 12	10,6	Критический
Пользователь 8	9	Критический
Пользователь 20	8,1	Критический
Пользователь 9	8	Критический
Пользователь 19	8	Критический
Пользователь 25	8	Критический
Пользователь 30	8	Критический
Пользователь 34	8	Критический
Пользователь 42	8	Критический
Пользователь 43	7,8	Высокий
Пользователь 1	7	Высокий
Пользователь 16	7	Высокий
Пользователь 17	7	Высокий
Пользователь 35	7	Высокий

2.1 Резюме по топ-нарушителям

Среди высокорискованных пользователей выделяются категории угроз:

- **Инфраструктурные риски** (Сотрудники, 8, 42):
Прямая компрометация периметра из-за утечки учетных данных в мессенджеры и соцсети
- **Возможные инсайдеры** (Сотрудник 20):
Нетипичный для роли сотрудника сбор персональных данных на внешний накопитель.
- **Источники массовых утечек и ИИ** (Сотрудники 12, 9, 19, 25, 30, 34, 43):
Передача тысяч строк с ПДн, врачебной и коммерческой тайной вовне.

3. Повторяющиеся нарушения

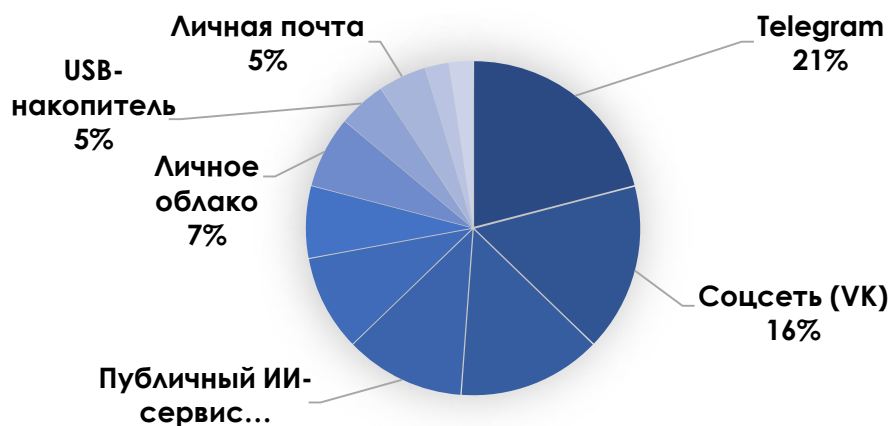
При анализе инцидентов можно определить ряд паттернов поведения сотрудников, которые создают системные риски для компании:

1. Использование личных мессенджеров/соцсетей для рабочих задач;
2. Использование публичного ИИ для обработки закрытых данных.
3. Игнорирование базовых политик ИБ и управления доступом;
(уязвимые доменные пароли, открытая передача учетных данных в мессенджеры, нерегламентированное ПО на рабочих станциях).

Основные каналы утечки

На основе логов DLP-системы идентифицированы следующие основные векторы утечки корпоративных данных:

Канал утечки	Доля от инцидентов
Telegram	21%
VK	16%
Публичные ИИ-сервисы	12%
Публичные хранилища	7%
USB-накопитель	5%



4. Рекомендации

4.1 Расследование обнаруженных инцидентов

4.1.1 Локализация угроз:

- Принудительно завершить сессии и сбросить утекшие пароли:
 - Сотрудник 8: УЗ от AD и Google Workspace;
 - Сотрудник 42: 254 УЗ от МИС;
 - Сотрудник 35: УЗ партнеров;
- Обновить слабые доменные пароли УЗ Сотрудников 11, 12, 13 и 14;

4.1.2 Проведение опросов нарушителей:

- Инициировать процедуру объяснительных / очного интервью с:
 - Сотрудником 20: для установления факта и мотива выгрузки данных на внешний USB-носитель;
 - Сотрудником 12: для установления факта и мотива отправки данных в соцсеть (есть вероятность компрометации УЗ).

4.1.3 Оценка юридических рисков:

- Оценить объем утекших ПДн и врачебной тайны для принятия решения о необходимости уведомления Роскомнадзора.

4.2 Технические меры

4.2.1 Аудит прав доступа:

- Провести ревизию доступа к общим ресурсам (\dfs\Share\...), и отозвать избыточные права на чтение директорий с ПДн у непрофильных подразделений.

4.2.2 Контроль устройств:

- На уровне EPP/EDR или групповых политик настроить логирование или запрет на использование съемных носителей.

4.2.3 Обновление политик DLP для контроля векторов:

- Мессенджеры и соцсети;
- Облачные хранилища.

4.2.4 ИИ-сервисы (выбрать возможное на текущий момент):

- Фильтрация ИИ-трафика (AI Gateway);
- Активировать профильные модули контроля в DLP-системе;
- Запретить трафик до ИИ-сервисов на NGFW;

4.2.5 Контроль приложений (выбрать возможное на текущий момент):

- Ввести политику контроля приложений в EPP/EDR;
- Провести инвентаризацию на наличие ПО из инцидентов: VanyaVPN, Torrent, автокликеры GSAutoClicker.

4.3 Организационные меры

- Разработать политику использования ИИ и провести целевое обучение руководящего состава;
- Провести инструктаж всего персонала по недопустимости обработки конфиденциальных данных в мессенджерах и соцсетях;
- Поставить на повышенный мониторинг в SIEM «необучаемых» сотрудников, сотрудников в активном поиска работы и с задолженностями в МФО.